

SUMMARY REPORT

REvil

MATTHEW BOUTILIER | W0498901

ISEC 1005 | RON MCLEOD

ASSIGNMENT TWO | CYBER CRIME SURVEY



TABLE OF CONTENTS

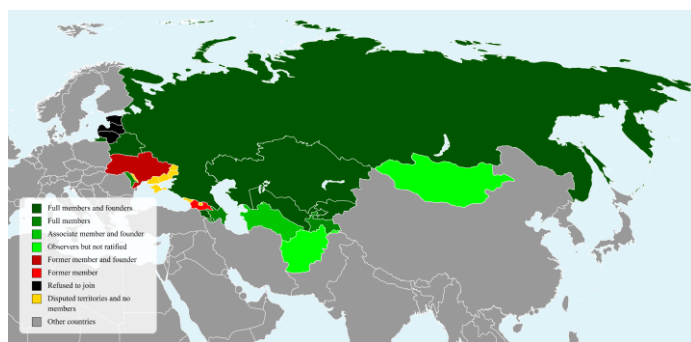
Origins & Methods	1
Spread	1
Mechanisms	2
Impact	3
Aftermath	3
References	4

ORIGINS & METHODS

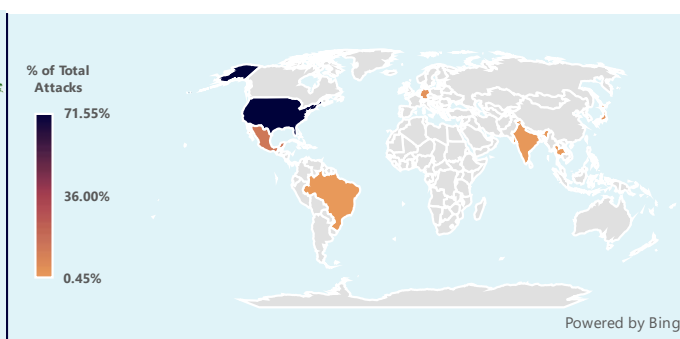
REvil is believed to be an offshoot of the now-defunct ransomware group *GandCrab* and is now believed to have been affiliated with the hacker group *DarkSide*. However, the basis for their relationship and the identity of its members is still unknown (Abrams, 2019). The group created the Sodinokibi ransomware and marketed it as ransomware-as-a-service (RaaS) in 2018—2019, which compromised devices through multiple vectors including hardware and software zero-day vulnerabilities, Remote Desktop Protocol breaches, and phishing emails (Akamai, n.d.). The ransomware exploited devices using DLL side-loading, which would replace **MpSvc.dll** with a malicious duplicate that is automatically run by Microsoft Defender. Giving the file the illusion of authenticity and allowing the export function titled **ServiceCrtMain** to run with the approval of the devices antivirus system(s). Once the malicious file is executed, it would perform a language and keyboard configuration test to verify it would not infect a blacklisted device (Krishnasamy et al., 2021), *see the ‘Spread’ section for more details*.

SPREAD

According to Trend Micro, the Sodinokibi ransomware attacks affected a total of 25,008 systems, with 17,893 incidents occurring in the USA, 3,527 in Mexico, and 859 in Germany. The ransomware was designed with a self-check/blacklist function to avoid infecting machines within the Commonwealth of Independent States (CIS) (Trend Micro Research, 2021). The CIS is an intergovernmental organization that operates primarily in Russian, with administrative centers located in Minsk and Moscow. It is comprised of nine member states: Armenia, Azerbaijan, Belarus, Kazakhstan, Kyrgyzstan, Russia, Tajikistan, and Uzbekistan, while Turkmenistan holds associate status (Krishnasamy et al., 2021). Moldova recently suspended its participation in May 2023 in an effort to distance itself from Russia and become more aligned with the European Union, however, officially it is still a member of the CIS (Popusoi, 2023).



*Map showing member and associate states of the Commonwealth of Independent States (CIS).
(Kulalov, 2022)*



*Map showing countries affected by REvil ransomware from January 1 to December 6, 2021.
(Trend Micro Research, 2021)*

After the malware ran its location check, it would run the **CreateToolhelp32Snapshot**, **Process32FirstW**, and **Process32NextW** processes to create a list of running processes and then compare them to a pre-determined list of Windows processes and stop them if there is a match. Once the processes are terminated, the malware encrypts files using a Salsa20 algorithm and changes the victim's desktop background to a ransom note, along with placing a file titled **readme.txt** on the desktop with instructions for payment of the ransom (MalwareBytes Labs, n.d.).

Anonymized Example of readme.txt

```
===== Welcome. Again. =====
```

[+] What Happened? [+]

Your files are encrypted, and currently unavailable. You can check it: all files on you computer has expansion l0z1752swt.

By the way, everything is possible to recover (restore), but you need to follow our instructions. Otherwise, you cant return your data (NEVER).

[+] What guarantees? [+]

Its just a business. We absolutely do not care about you and your deals, except getting benefits. If we do not do our work and liabilities - nobody will not cooperate with us. Its not in our interests. To check the ability of returning files, You should go to our website. There you can decrypt one file for free. That is our guarantee.

If you will not cooperate with our service - for us, it does not matter. But you will lose your time and data, cause just we have the private key. In practise - time is much more valuable than money.

[+] How to get access on website? [+]

You have two ways:

1) [Recommended] Using a TOR browser!

a) Download and install TOR browser from this site: <https://torproject.org/>

b) Open our website: <http://aplezbzu47wgazapdqks6vr6czjnpkxbr6wketf56nf6aq2nmyoyd.onion/????????????????>

2) If TOR blocked in your country, try to use VPN! But you can use our secondary website. For this:

a) Open your any browser (Chrome, Firefox, Opera, IE, Edge)

b) Open our secondary website: <http://decryptor.top/????????????????>

Warning: secondary website can be blocked, thats why first variant much better and more available.

When you open our website, put the following data in the input form:

Key:

[illegible]

Extension name:

10z1752swt

!!! DANGER !!!

DONT try to change files by yourself, DONT use any third party software for restoring your data or antivirus solutions - its may entail damage of the private key and, as result, The Loss all data.

!!! !!! !!! !!!

ONE MORE TIME: Its in your interests to get your files back. From our side, we (the best specialists) make everything for restoring. But please should not interfere.

IMPACT

In less than eighteen months of operation, REvil's ransomware was behind multiple high-profile incidents, including the theft of approximately 1TB of data from the law firm Grubman Shire Meiselas & Sacks in May 2020. This firm represents high-profile clients, including celebrities like Lady Gaga, Madonna, and Donald Trump. REvil was also used in an attempt to extort Apple Inc. by stealing product schematics in April 2021. Additionally, in July 2021, it was used in an attack on HX5, an American defense contractor based in Florida. Which brought the ransomware to the attention of the US government (Avast Business, n.d.). The ransom was set on a case-by-case basis. In the case of Grubman Shire Meiselas & Sacks, a ransom of USD \$42,000,000, equivalent in bitcoin, was demanded to prevent the release of documents related to Donald Trump. In May 2021, JBS S.A., a multi-national beef processing company, was forced to shut down its US and Australian operation after being infected with Sodinokibi, JBS's ransom was set at USD\$11,000,000, which was paid to REvil via a Bitcoin transfer (Batista & Hirtzer, 2021).

AFTERMATH

REvil went dark in late-2021, and the circumstances surrounding its demise are still in question. One possibility is that they didn't want to deal with the negative attention they were receiving after President Biden demanded the Russian Federation work towards shutting down ransomware groups targeting American businesses. Another possibility is that Russian President Vladimir Putin acted on President Biden's demand and the Russian Government disbanded REvil (Sanger, 2021). Since

President Biden's demand in 2021, the Russian FSB has released video of the arrests of REvil leaders, although it is not believed that any of the arrestees will be extradited to the US. The American Government has a standing bounty on information pertaining to REvil members, set at USD\$10,000,000. In the arrests, the FSB seized ₪426,000,000 including approximately ₪47,000,000 in crypto currency, and over twenty premium cars that were deemed to be purchased with proceeds of a crime (Tidy, 2022).



*Photo of the arrest of an REvil member in Russia.
(FSB via Tidy, 2022)*



REFERENCES

- Abrams, L. (2019, October 14). Sodinokibi ransomware: Following the affiliate money trail. Bleeping Computer.
<https://www.bleepingcomputer.com/news/security/sodinokibi-ransomware-following-the-affiliate-money-trail/>
- Akamai (n.d.). What Is REvil? Akamai. <https://www.akamai.com/glossary/what-is-revil>
- Avast Business (n.d.). What is Sodinokibi (REvil) ransomware? Avast Business.
<https://www.avast.com/business/resources/what-is-sodinokibi-ransomware#pc>
- Batista, F., & Hirtzer, M. (2021, June 10). JBS Paid Hackers \$11 Million After Hack Crippled Meat Plants. Bloomberg.
<https://www.bloomberg.com/news/articles/2021-06-09/jbs-paid-11-million-in-ransom-to-resolve-cyberattack-dj?sref=ClpmV6x8>
- Krishnasamy, V., Karthickkumar, & Jaiswal, S. (2021, July 16). REvil Ransomware Uses DLL Sideloads. McAfee Labs. <https://www.mcafee.com/blogs/other-blogs/mcafee-labs/revil-ransomware-uses-dll-sideloads/>
- Kulolov, F. (2022). Commonwealth of Independent States (CIS) – Содружество Независимых Государств (СНГ). Wikimedia Commons [Photograph]. [https://wikipedia.org/Commonwealth_of_Independent_States_\(CIS\)_-_Содружество_Независимых_Государств_\(СНГ\)](https://wikipedia.org/Commonwealth_of_Independent_States_(CIS)_-_Содружество_Независимых_Государств_(СНГ))
- MalwareBytes Labs (n.d.). Ransom.Sodinokibi. MalwareBytes Labs.
<https://www.malwarebytes.com/blog/detections/ransom-sodinokibi>
- Popusoi, C. (2023, May 18). Moldova Is Distancing Itself From The CIS, But Leaving Might Not Be So Easy. Radio Free Europe Radio Liberty. <https://www.rferl.org/a/moldova-leaving-cis-russia/32417644.html>
- Sanger, D. E. (2021, July 13). <https://www.nytimes.com/2021/07/13/us/politics/russia-hacking-ransomware-rev.html>
- revTidy, J. (2022, January 14). REvil ransomware gang arrested in Russia. BBC.
<https://www.bbc.com/news/technology-59998925>
- <https://www.nytimes.com/2021/07/13/us/politics/russia-hacking-ransomware-revil.html>
- Trend Micro Research. (2021, December 20). REvil. Trend Micro Business.
<https://www.trendmicro.com/vinfo/us/security/news/ransomware-spotlight/ransomware-spotlight-revil>